Grundlagen der Resilienz: Safety & Security

Vorlesungsskript · Sitzung 1 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

1. Einleitung und Lernziele

Dieses Skript begleitet die erste Sitzung des Moduls „Grundlagen der Resilienz“. Ziel ist es, einen wissenschaftlich fundierten, aber anwendungsnahen Einstieg in die Terminologie und Basiskonzepte von Resilienz zu vermitteln und diese in den Kontext der Cyber Security einzuordnen.

Lernziele:

- den Begriff der Resilienz definieren und von Robustheit, Zuverlässigkeit und Sicherheit abgrenzen;
- den Unterschied zwischen Safety (Betriebssicherheit) und Security (Angriffssicherheit) erläutern;
- technische und organisatorische Resilienzprinzipien benennen und anwenden;
- Resilienz in Cyber-Security-Management, Business Continuity und Incident Response einordnen.

2. Begriff und Bedeutung von Resilienz

Resilienz bezeichnet die Fähigkeit eines Systems, trotz interner oder externer Störungen funktionsfähig zu bleiben, die Funktionsfähigkeit rasch wiederherzustellen und sich im Zeitverlauf anzupassen. In der Cyber-Sicherheit ergänzt Resilienz die klassische Prävention um frühzeitiges Erkennen (Detection), wirksame Reaktion (Response) und schnelle Wiederherstellung (Recovery), vgl. NIST SP 800-160 Vol. 2.

3. Historische und theoretische Grundlagen

Der Resilienzbegriff hat Wurzeln in Materialwissenschaft, Psychologie und Systemtheorie. Resilience Engineering (Hollnagel, Woods & Leveson, 2006) betont vier Fähigkeiten soziotechnischer Systeme: anticipate, monitor, respond, learn.

4. Abgrenzung von Safety und Security

Safety: Schutz vor unbeabsichtigten Ereignissen/Fehlern (z. B. Hardwaredefekte, Stromausfall).

Security: Schutz vor absichtlichen, intelligenten Bedrohungen (z. B. Ransomware, Social Engineering).

Resilienz integriert beide Perspektiven und adressiert Übergänge in vernetzten OT/IoT-Kontexten.

5. Technische und organisatorische Prinzipien der Resilienz

- Redundanz (Mehrfachressourcen, Multi-AZ/Region).
- Diversität (heterogene Implementierungen, Lieferantenvielfalt).
- Wiederherstellbarkeit (geplante, getestete und automatisierte Wiederanlaufprozesse) – vgl. ISO/IEC 27031, BSI 200-4.
- Adaptivität (dynamische Anpassung, Skalierung, Chaos-Engineering als Testmethode).

6. Systemische und physikalische Perspektive

Resilienz als Fähigkeit zur Rückkehr in einen akzeptablen Funktionszustand nach Auslenkung (Analogie: gedämpfter Schwingkreis). In IT-Systemen übernehmen Kontrollschleifen (Monitoring, Alerting, Autoscaling) die Rolle von Regelkreisen.

7. Resilienz im Kontext der Cyber Security

NIST SP 800-160 Vol. 2 operationalisiert Resilienz u. a. über resist, recover, re-constitute, re-architect. ISO/IEC 27031 adressiert ICT Readiness for BC; der BSI-Standard 200-4 fokussiert BCM; ENISA veröffentlicht sektorspezifische Resilienz-Leitfäden.

> **i** Hinweis zur Aktualität
>
> NIST SP 800-160 Vol. 2 Rev. 1 (2021) definiert Cyber-Resilienz über die Ziele *Anticipate, Withstand, Recover, Adapt* [1]. Die hier verwendeten Begriffe (resist, re-constitute u. a.) stammen aus älteren Fassungen bzw. der Terminologie der Lehrveranstaltung. ISO/IEC 27031 ist 2025 neu erschienen („Cybersecurity – Information and communication technology readiness for business continuity“) [2]. Siehe Quellen, Hinweis 1, Quellen, Hinweis 2.

8. Praxisbeispiele und Fallstudien

Ransomware in einer Verwaltung: Koordiniertes Incident- und Krisenmanagement, offline verifizierte Backups, priorisierter Wiederanlauf gemäß BCM-Plan (BSI 200-4).

DDoS auf Online-Dienst: Anycast/CDN/WAF, elastische Skalierung, transparente Status-Kommunikation; Übungen (Game Days).

Smart Home/OT: Safety-Ereignis → Security-Vektor; Segmentierung, sichere Updates, Fail-Safe-Modi.

9. Übung: Safety oder Security?

Analysieren Sie ein Szenario (Cloud-Gaming, Krankenhaus-IT, Smart Home, autonomes Fahrzeug, Banking-App). Identifizieren Sie Safety- und Security-Risiken, schlagen Sie Resilienzmaßnahmen vor und priorisieren Sie kritische Funktionen.

10. Zusammenfassung und Ausblick

Resilienz erweitert die klassische Sicherheit um Anpassungs- und Wiederherstellungsfähigkeit. Safety und Security beeinflussen Resilienz gleichermaßen. Technische und organisatorische Prinzipien müssen zusammenwirken. In Sitzung 2 werden Modelle und Metriken (RTO/RPO, MTTR, SLOs) vertieft.

11. Prüfungsrelevanz – Lernfragen & Kernpunkte

Beispielfragen:

1. Definieren Sie Resilienz im Kontext von IT-Systemen und grenzen Sie den Begriff von Robustheit ab.
2. Erläutern Sie den Unterschied zwischen Safety und Security und nennen Sie je ein Beispiel aus IT/OT.

3. Nennen und erklären Sie drei technische Prinzipien, die Resilienz erhöhen (mit kurzen Beispielen).
4. Skizzieren Sie die Rolle von ISO/IEC 27031 und BSI-Standard 200-4 für Wiederanlauf und BCM.
5. Beschreiben Sie den Detect–Respond–Recover-Gedanken nach NIST SP 800-160 Vol. 2.

Kernpunkte:

- „Sicherheit schützt – Resilienz überlebt." Prävention ist notwendig, aber nicht hinreichend.
- Safety und Security adressieren unterschiedliche Ursachen – Resilienz integriert beide Perspektiven.
- Design for Failure: Redundanz, Diversität, Wiederherstellbarkeit und Adaptivität sind Leitplanken.
- Resilienz erfordert Technik, Prozesse und Menschen – und lebt von Übung und Lernen.

Literatur und Normen (Auswahl)

- NIST SP 800-160 Vol. 2: Developing Cyber-Resilient Systems (Systems Security Engineering). National Institute of Standards and Technology.
- ISO/IEC 27031: Guidelines for ICT Readiness for Business Continuity (IRBC). International Organization for Standardization / IEC.
- BSI-Standard 200-4: Business Continuity Management. Bundesamt für Sicherheit in der Informationstechnik.
- Hollnagel, E.; Woods, D. D.; Leveson, N. (2006): Resilience Engineering: Concepts and Precepts. Ashgate.
- ENISA: Reports zur Cybersecurity- und Resilienz kritischer Infrastrukturen.

Bibliografie

[1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach", NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: 10.6028/NIST.SP.800-160v2r1.

[2] „ISO/IEC 27031:2025 Cybersecurity – Information and communication technology readiness for business continuity". [Online]. Verfügbar unter: https://www.iso.org/standard/27031